

Modelo de encuesta integral sobre KEV, vulnerabilidades, pentesting, SIEM y capacitación

Instrucciones generales

- Esta encuesta está pensada para ser respondida por el equipo responsable de ciberseguridad (idealmente, de forma conjunta).
- No hay respuestas «buenas» o «malas»: solo fotografías más o menos nítidas de la realidad.
- Elija siempre la opción que **mejor describa la práctica habitual**, no la deseable ni la que figura en la presentación corporativa.

Cada pregunta incluye un identificador (por ejemplo, GOV-01) para facilitar el análisis posterior.

Bloque 0. Perfil de la organización (PERF)

PERF-01. Tipo de organización

(Seleccione la opción principal)

- a) Administración pública.
- b) Empresa privada.
- c) Entidad sin ánimo de lucro.
- d) Otro tipo (especificar).

PERF-02. Tamaño aproximado de la organización

- a) Micro (hasta 10 personas).
- b) Pequeña (11–50 personas).
- c) Mediana (51–250 personas).
- d) Grande (más de 250 personas).

PERF-03. Sector de actividad principal

- a) Sector público / Administración.
- b) Finanzas y seguros.
- c) Sanidad y servicios sociales.
- d) Industria y energía.
- e) TIC y servicios digitales.
- f) Educación e investigación.
- g) Otros sectores.

PERF-04. Ámbito geográfico predominante

- a) Local / regional.
- b) Nacional.
- c) Multinacional con presencia en la UE.
- d) Multinacional global.

Bloque 1. Gobierno y estrategia de vulnerabilidades (GOV)

GOV-01. Política de gestión de vulnerabilidades y KEV

- a) No existe política formal de gestión de vulnerabilidades.
- b) Existe política formal, pero no menciona explícitamente KEV.
- c) Existe política formal que menciona KEV, pero sin criterios claros de priorización.
- d) Existe política formal que integra KEV como elemento central de priorización y se revisa periódicamente.

GOV-02. Asignación de responsabilidades sobre KEV

- a) No hay responsables claramente definidos; «es cosa de TI» en general.
- b) Existe un responsable técnico informal, sin respaldo explícito de la dirección.
- c) Hay un responsable formal de gestión de vulnerabilidades/KEV con mandato definido.
- d) Existen responsables formales y un órgano de gobierno (comité, etc.) que supervisa periódicamente el estado de KEV.

GOV-03. Integración de KEV en la gestión de riesgos

- a) KEV no se consideran específicamente en el análisis de riesgos.
- b) KEV se tienen en cuenta de forma ad hoc cuando aparece un aviso especialmente preocupante.
- c) KEV se integran de forma sistemática en los registros de riesgo de TI/ciberseguridad.
- d) KEV se integran en los registros de riesgo corporativo y se reportan a la alta dirección.

GOV-04. Frecuencia de revisión del catálogo KEV frente al entorno de la organización

- a) No se revisa de manera sistemática.
- b) Se revisa de forma esporádica (alguna vez al año, cuando hay tiempo).
- c) Se revisa al menos mensualmente.
- d) Se revisa semanal o diariamente, con procesos definidos de correlación.

GOV-05. Criterios de priorización de vulnerabilidades

- a) Se parchea «lo que se puede» según urgencias percibidas.
- b) Se prioriza principalmente por CVSS u otro indicador de severidad técnica.
- c) Se prioriza combinando CVSS con la etiqueta KEV y consideraciones de negocio.
- d) Se prioriza utilizando un marco formal que integra KEV, CVSS/EPSS y contexto de negocio (impacto, exposición, cumplimiento).

GOV-06. Definición de objetivos y SLAs de remediación para KEV

- a) No hay objetivos ni plazos definidos para remediar KEV.
- b) Hay objetivos genéricos (por ejemplo, «parchear lo antes posible»), no medidos.
- c) Existen SLAs específicos para KEV, pero no se monitoriza sistemáticamente su cumplimiento.
- d) Existen SLAs específicos para KEV, se monitorizan y se reporta su cumplimiento a la dirección.

Bloque 2. Gestión operativa de vulnerabilidades y KEV (VUL)

VUL-01. Inventario de activos

- a) No existe inventario actualizado de activos relevantes (servidores, dispositivos perimetrales, aplicaciones clave...).
- b) Existe inventario parcial y desactualizado.
- c) Existe inventario razonablemente completo y se actualiza con cierta regularidad.
- d) Existe inventario completo, automatizado y trazable (CMDB o equivalente), integrado con herramientas de seguridad.

VUL-02. Detección de vulnerabilidades y etiquetado KEV

- a) No se utilizan herramientas de escaneo de vulnerabilidades.
- b) Se utilizan escáneres puntualmente, sin etiquetado específico de KEV.
- c) Se utilizan escáneres que reconocen KEV, pero sin procesos formales de explotación de esa información.
- d) Se utilizan escáneres y/o plataformas ASM que etiquetan KEV y alimentan automáticamente los procesos de priorización.

VUL-03. Correlación entre KEV y activos expuestos

- a) No se realiza correlación entre KEV y los activos de la organización.
- b) Se realiza correlación manual y puntual cuando hay avisos críticos.
- c) Existe un proceso semiautomatizado de correlación periódica.
- d) La correlación KEV-activos está automatizada y se ejecuta como parte de los flujos estándar de gestión de vulnerabilidades.

VUL-04. Medición del tiempo de remediación de KEV

- a) No se mide el tiempo que transcurre entre la inclusión de una KEV y su remediación.
- b) Se mide de forma informal o en casos concretos.
- c) Se mide sistemáticamente para KEV críticas y altas.
- d) Se mide sistemáticamente para todas las KEV y se comparan con objetivos definidos.

VUL-05. Porcentaje de KEV remediadas dentro del plazo objetivo

- a) No se dispone de este dato.
- b) Se estima que la mayoría de las KEV se remedia fuera de plazo.
- c) Aproximadamente la mitad de las KEV se remedia dentro de plazo.
- d) La mayoría de las KEV se remedia dentro de plazo y se hace seguimiento de los casos retrasados.

VUL-06. Tratamiento de dispositivos perimetrales y appliances críticos

- a) No se distingue entre vulnerabilidades en dispositivos perimetrales y en otros sistemas.
- b) Se presta atención especial a firewalls/VPN, pero sin procesos documentados.
- c) Existen procesos específicos para priorizar y parchear vulnerabilidades (incluidas KEV) en el perímetro.
- d) Existe un programa formal de gestión de riesgos del perímetro con controles técnicos y de proceso claramente definidos.

VUL-07. Gestión de sistemas legacy y vulnerabilidades antiguas

- a) Los sistemas legacy con vulnerabilidades conocidas se mantienen «mientras aguanten».
- b) Se aplican mitigaciones parciales, sin un plan claro de sustitución.
- c) Existen planes de sustitución o aislamiento progresivo para sistemas legacy vulnerables.
- d) Se gestiona sistemáticamente el ciclo de vida y se minimiza la exposición a vulnerabilidades antiguas mediante sustitución, segmentación y compensación.

Bloque 3. Pruebas de penetración y ejercicios (PEN)

PEN-01. Frecuencia de pruebas de penetración

- a) No se realizan pruebas de penetración.
- b) Se realizan de forma esporádica (menos de una vez cada dos años).
- c) Se realizan al menos anualmente en los sistemas críticos.
- d) Se realizan pruebas regulares y específicas (incluyendo pruebas tras cambios significativos y despliegue de nuevos servicios).

PEN-02. Cobertura de KEV en las pruebas de penetración

- a) Las pruebas no consideran explícitamente vulnerabilidades KEV.
- b) Se incluye alguna referencia a KEV cuando el proveedor lo propone.
- c) El alcance de las pruebas se define teniendo en cuenta las KEV relevantes para la organización.
- d) Existe un alineamiento sistemático entre el catálogo de KEV y los escenarios de prueba (incluyendo campañas de threat hunting y ejercicios Red/Purple Team).

PEN-03. Gestión de hallazgos de pentest

- a) Los informes de pentest se archivan con cariño y poca acción.
- b) Se corrigen algunos hallazgos críticos, sin trazabilidad completa.
- c) Existe un proceso formal de registro, priorización y seguimiento de hallazgos.
- d) Los hallazgos se integran en la gestión de vulnerabilidades y en los registros de riesgo, con seguimiento hasta cierre.

PEN-04. Uso de ejercicios Red/Purple Team

- a) No se realizan este tipo de ejercicios.
- b) Se han realizado ejercicios puntuales como demostración.
- c) Se realizan ejercicios planificados para probar escenarios específicos (incluyendo explotación de KEV).
- d) Existe un programa continuado de ejercicios Red/Purple Team, integrado con la mejora del SOC y los procesos de respuesta.

PEN-05. Verificación del cierre de KEV mediante pruebas

- a) No se verifica específicamente el cierre de KEV mediante pruebas.
- b) Se realizan pruebas manuales ad hoc para algunas KEV críticas.
- c) Se incluyen pruebas de verificación de cierre en el ciclo estándar de gestión de parches.
- d) Se combinan pruebas automatizadas y manuales para verificar sistemáticamente el cierre de KEV especialmente relevantes.

Bloque 4. Monitorización, SIEM y detección (SIEM)

SIEM-01. Situación de SIEM/SOC

- a) No se dispone de SIEM ni de SOC.
- b) Se dispone de registros dispersos y cierto monitoreo manual.
- c) Se dispone de SIEM/SOC parcial (por ejemplo, horario laboral, cobertura limitada).
- d) Se dispone de SIEM/SOC con monitoreo estructurado (idealmente 24x7, interno o externalizado).

SIEM-02. Casos de uso para detección de explotación de vulnerabilidades

- a) No existen casos de uso específicos relacionados con explotación de vulnerabilidades.
- b) Existen algunas reglas genéricas de detección de anomalías o firmas.
- c) Existen casos de uso definidos para detectar explotación de vulnerabilidades críticas y KEV relevantes.
- d) Los casos de uso se actualizan de forma sistemática en función de nuevas KEV y de la inteligencia de amenazas.

SIEM-03. Fuentes de logs y visibilidad

- a) Se recopilan pocos registros y no necesariamente de los sistemas más críticos.
- b) Se recopilan logs de algunos sistemas clave (por ejemplo, firewalls), pero no de forma integral.
- c) Se recopilan logs de la mayoría de sistemas críticos, incluyendo perímetro, servidores y aplicaciones relevantes.
- d) La recolección de logs cubre de forma sistemática los sistemas críticos, dispositivos perimetrales, aplicaciones expuestas, plataformas CI/CD y otros elementos clave.

SIEM-04. Integración de inteligencia de amenazas

- a) No se utiliza inteligencia de amenazas.
- b) Se consultan ocasionalmente fuentes públicas o boletines.
- c) Se utilizan feeds de inteligencia y se integran parcialmente en el SIEM.
- d) Existe integración estructurada de inteligencia de amenazas (incluyendo KEV) en el SIEM y los casos de uso.

SIEM-05. Capacidad de detección basada en comportamiento

- a) La detección se basa casi exclusivamente en firmas y reglas estáticas.
- b) Se utilizan algunas capacidades básicas de detección de anomalías.
- c) Se emplean herramientas de EDR/NDR/UEBA con uso activo de sus capacidades.
- d) La detección basada en comportamiento es un pilar del SOC, con tuning y revisión continua.

SIEM-06. Medición del tiempo medio de detección (MTTD) de incidentes relacionados con vulnerabilidades

- a) No se mide el MTTD.
- b) Se dispone de estimaciones aproximadas en algunos casos.
- c) Se mide el MTTD para una parte de los incidentes.
- d) Se mide sistemáticamente el MTTD y se utilizan los resultados para mejorar procesos y capacidades.

Bloque 5. Capacitación y cultura de seguridad (AWR)

AWR-01. Programa de formación general en seguridad

- a) No existe programa de formación estructurado.
- b) Se ofrecen formaciones puntuales o materiales esporádicos.
- c) Existe un programa anual de formación obligatoria para el personal.
- d) Existe un programa continuo y segmentado (por perfiles), con seguimiento de participación y resultados.

AWR-02. Formación específica para perfiles técnicos sobre vulnerabilidades y KEV

- a) No se ofrece formación específica más allá del autoaprendizaje.
- b) Se ofrecen ocasionalmente formaciones o webinars técnicos.
- c) Existe un plan de formación técnica recurrente para administradores, desarrolladores y personal de seguridad.
- d) La formación técnica está alineada explícitamente con tendencias (incluidas KEV) y se revisa al menos anualmente.

AWR-03. Simulaciones y ejercicios de concienciación

- a) No se realizan simulaciones (phishing, ejercicios de respuesta, etc.).
- b) Se realizan campañas puntuales de phishing simulado.
- c) Se realizan campañas regulares y se analizan los resultados.
- d) Se combinan simulaciones de phishing, ejercicios de respuesta y campañas específicas ligadas a incidentes y vulnerabilidades recientes.

AWR-04. Cultura de reporte de incidentes y sospechas

- a) No existe un canal claro para reportar incidentes o comportamientos sospechosos.
- b) Existe un canal formal, pero la cultura de reporte es baja.
- c) El personal conoce los canales y los utiliza en cierta medida.
- d) La cultura de reporte está asentada y se refuerza activamente (comunicaciones, reconocimiento, etc.).

AWR-05. Medición de la eficacia de la capacitación

- a) No se mide la eficacia de la formación.
- b) Se mide únicamente la asistencia o finalización.
- c) Se realizan pruebas de conocimiento o ejercicios prácticos asociados a la formación.
- d) Se analizan resultados en el tiempo y se ajusta el programa en función de los mismos.

Bloque 6. Métricas, indicadores y ROI (MET)

MET-01. Indicadores sobre vulnerabilidades y KEV

- a) No se monitorizan indicadores relacionados con vulnerabilidades.
- b) Se monitoriza algún indicador básico (por ejemplo, número de vulnerabilidades abiertas).
- c) Se monitorizan indicadores específicos sobre KEV (número, tiempos de remediación, cumplimiento de plazos...).
- d) Existe un cuadro de mando de vulnerabilidades/KEV con indicadores regularmente revisados y utilizados en la toma de decisiones.

MET-02. Indicadores sobre pentesting y SIEM

- a) No se dispone de indicadores estructurados.
- b) Se recogen algunos datos (número de pruebas, volumen de alertas, etc.), sin análisis sistemático.
- c) Se monitorizan indicadores de rendimiento y eficacia (por ejemplo, número de hallazgos críticos, MTDD, MTTR).
- d) Los indicadores se analizan periódicamente y se utilizan para justificar recursos y reorientar estrategias.

MET-03. Uso de benchmarks y referencias externas

- a) No se utilizan benchmarks externos.
- b) Se consultan ocasionalmente informes de referencia (ENISA, CISA, etc.).
- c) Se comparan sistemáticamente algunos indicadores internos con benchmarks externos.
- d) Los resultados de benchmarking se integran en la planificación estratégica y en la comunicación con la dirección.

MET-04. Cálculo de ROI en iniciativas de seguridad

- a) No se considera el ROI en las decisiones de seguridad; se actúa por «necesidad percibida».
- b) Se estima el ROI de forma cualitativa en algunas iniciativas.
- c) Se realizan análisis cuantitativos básicos de coste/beneficio.
- d) El cálculo de ROI (incluyendo reducción de pérdida esperada asociada a vulnerabilidades/KEV) forma parte habitual de los business case de seguridad.

MET-05. Madurez percibida en gestión de vulnerabilidades y KEV

En una escala de 1 a 5, donde 1 es «Muy baja» y 5 es «Muy alta», ¿cómo valoraría la madurez global de su organización en gestión de vulnerabilidades y KEV?

- 1) Muy baja.
- 2) Baja.
- 3) Media.
- 4) Alta.
- 5) Muy alta.

Bloque 7. Planes de mejora y obstáculos (IMP)

IMP-01. Existencia de un plan de mejora específico

- a) No existe un plan de mejora específico en gestión de vulnerabilidades/KEV.
- b) Se contemplan acciones de mejora dispersas en distintos planes.
- c) Existe un plan de mejora definido, pero con ejecución parcial.
- d) Existe un plan de mejora priorizado, con responsables, plazos y seguimiento.

IMP-02. Principales obstáculos percibidos

(Selección múltiple)

- a) Recursos económicos limitados.
- b) Falta de personal especializado.
- c) Complejidad técnica/legada del entorno.
- d) Falta de apoyo o comprensión por parte de la dirección.
- e) Sobrecarga operativa y falta de tiempo.
- f) Otros (especificar).

IMP-03. Comentarios y sugerencias adicionales

(Pregunta abierta)

- Espacio para que la organización añada cualquier comentario que considere relevante sobre su situación, prioridades o necesidades en materia de gestión de vulnerabilidades, KEV, pentesting, SIEM y capacitación.

Con esto concluye el cuestionario. Si han llegado hasta aquí, ya han demostrado un nivel notable de resiliencia... al menos frente a las encuestas. Ahora toca convertir las respuestas en decisiones.